



Au cœur de vos attentes. En réponse à vos besoins

Formation : ASRS / TISR

Module 3 : Les attaques sur le réseau



Table des matières

- 1 : Rappel des bases du réseau.
- 2 : Attaque sur les réseaux locaux.
- 3 : Attaque sur les réseaux sans fil.
- 4 : Manipulation des outils.
- 5 : Exploitation des vulnérabilités.

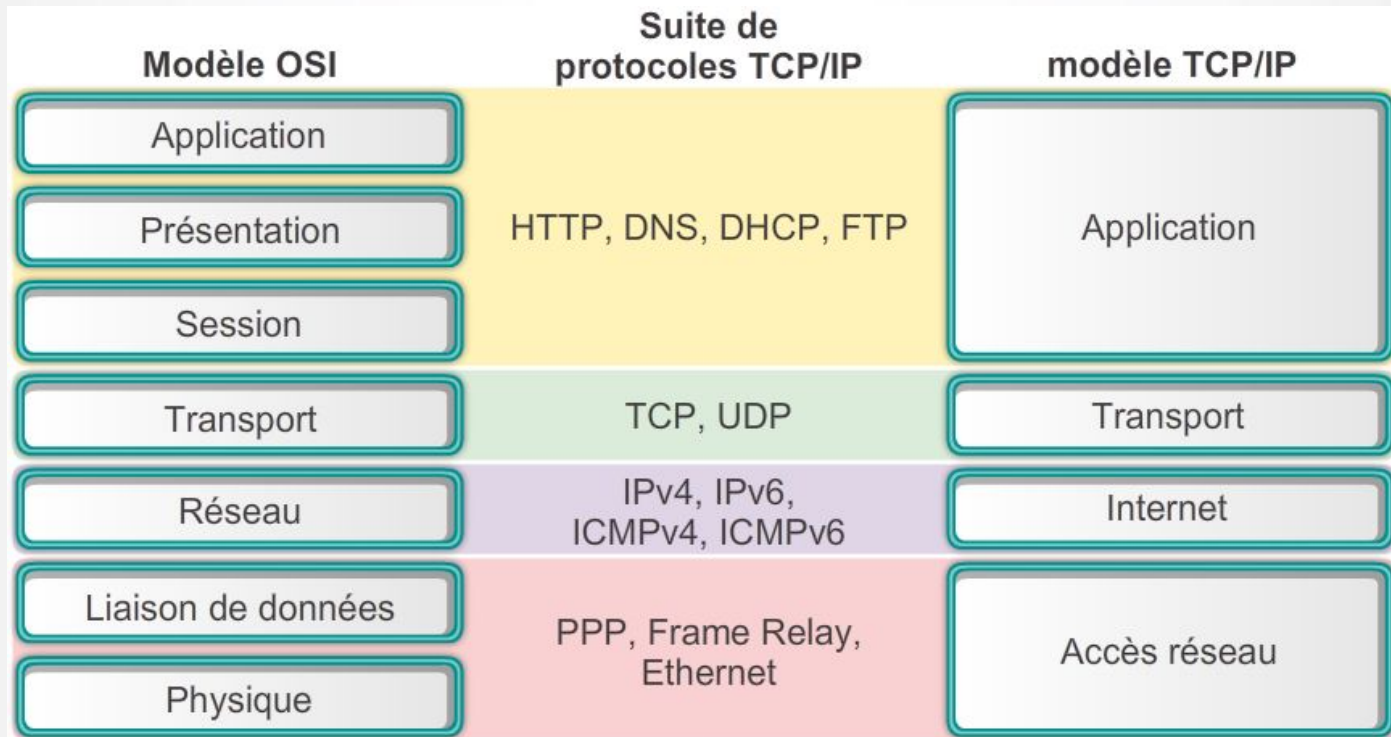




Rappel des bases du réseau



Le modèle OSI / Le modèle TCP/IP



L'adressage IPV4

Les adresses privées :

- De **10.0.0.0** à **10.255.255.255** soit **16 777 216** adresses.
- De **172.16.0.0** à **172.31.255.255** soit **1 048 576** adresses.
- De **192.168.0.0** à **192.168.255.255** soit **65 536** adresses.

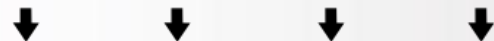
Le réseau **127.0.0.0** est réservé pour les tests de boucle locale.

- **127.0.0.1** est l'adresse localhost.

Toute autre adresse IPv4 est soit publique ou réservée.

Une adresse IPv4 (notation décimale à point)

172 . 16 . 254 . 1



10101100.00010000.11111110.00000001



L'adressage IPv6

Pénurie d'adresses IPv4 → Création des adresses IPv6

- De 4 octets à 16 octets (environ **3,4 x 10³⁸** d'adresses possibles).

Changement dans la structure

- De la notation décimale en IPv4 en notation hexadécimale en IPv6.
- Séparation de groupes d'octets avec des deux points en IPv6 au lieu d'un point en IPv4.

Différents format de représentation

- 2001:0db8:0000:85a3:0000:0000:ac1f:8001
- 2001:db8:0:85a3:0:0:ac1f:8001
- 2001:db8:0:85a3::ac1f:8001

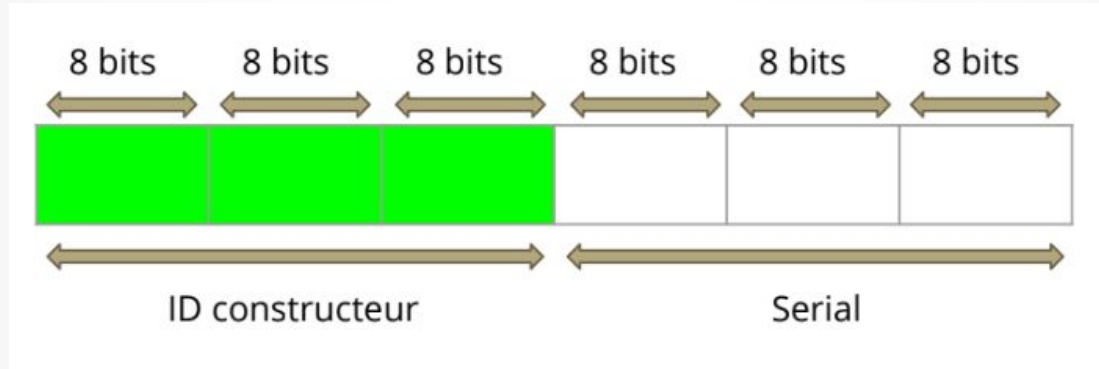
Bye bye le NAT!

L'adresse MAC

C'est une adresse permettant d'identifier de manière unique un matériel informatique comme étant connecté au réseau.

Elle est attribuée à un matériel de façon unique lors de sa fabrication.

- Et oui, une adresse MAC peut être changée !



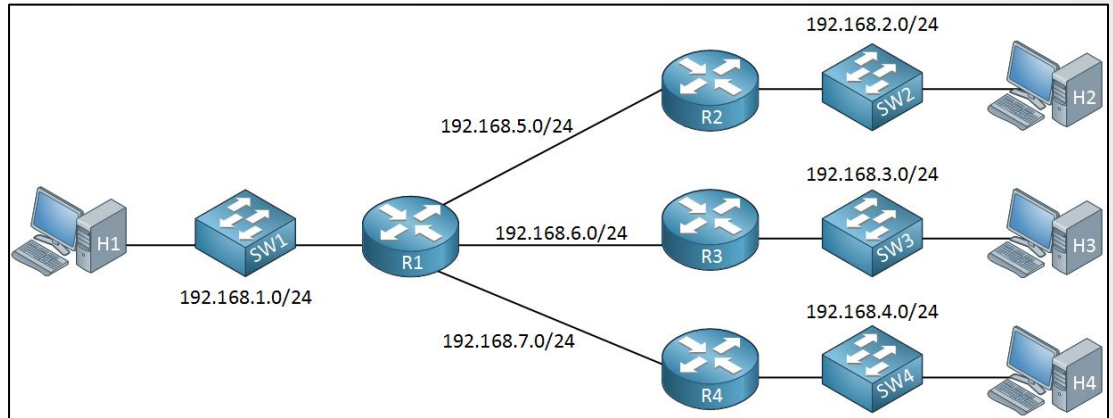
Les masques de sous-réseaux (Le subnetting)

Le subnetting permet de diviser un réseau large en plusieurs sous réseaux.

Il permet de définir à quel sous-réseau appartient l'adresse IP.

Elle possède la forme suivante :

- 255.255.255.0, 255.255.0.0 ...



L'adressage CIDR

C'est une méthode de regroupement d'adresses IP.

Elle permet d'éviter le gaspillage d'adresses en réduisant les plages.

Elle prend la forme 192.168.10.0/24.

Sous-réseau 1 : 192.168.0.0/24 → **11000000.10101000.00000000.00000000**/24

Sous-réseau 2 : 10.0.0.0/8 → **00001010.00000000.00000000.00000000**/8

Fonctionnement du protocole ARP

C'est un protocole de Résolution d'adresse permet de correspondre une adresse de niveau 3 (IPv4) à une adresse de niveau 2 (MAC).

Son but est, à partir d'une adresse IP connue d'une machine, obtenir son adresse MAC et ainsi pouvoir envoyer notre trame.

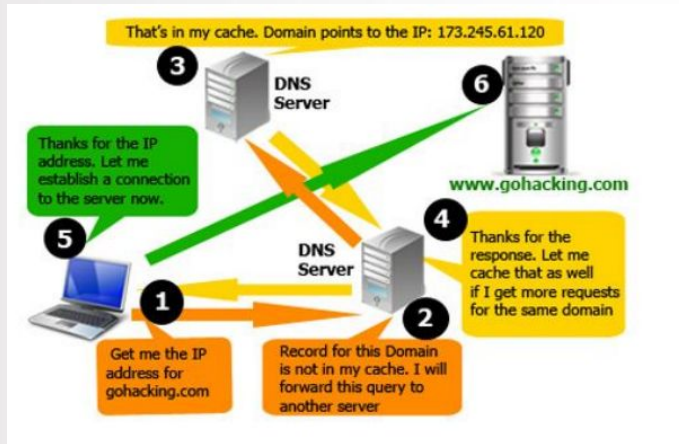
Source	Destination	Protocol	Length	Info
Sagemcom_5a:db:c0	SamsungE_c1:5d:d7	ARP	42	who has 192.168.1.20? Tell 192.168.1.254
SamsungE_c1:5d:d7	Sagemcom_5a:db:c0	ARP	42	192.168.1.20 is at e8:03:9a:c1:5d:d7
SamsungE_c1:5d:d7	Broadcast	ARP	42	who has 192.168.1.254? Tell 192.168.1.20
Sagemcom_5a:db:c0	SamsungE_c1:5d:d7	ARP	42	192.168.1.254 is at c8:cd:72:5a:db:c0

Fonctionnement du protocole DNS

C'est un protocole de Nom de Domaine qui permet de réaliser une correspondance entre un nom et une adresse IP.

- E.g : Le nom de domaine de l'adresse IP 216.58.206.228 est www.google.com

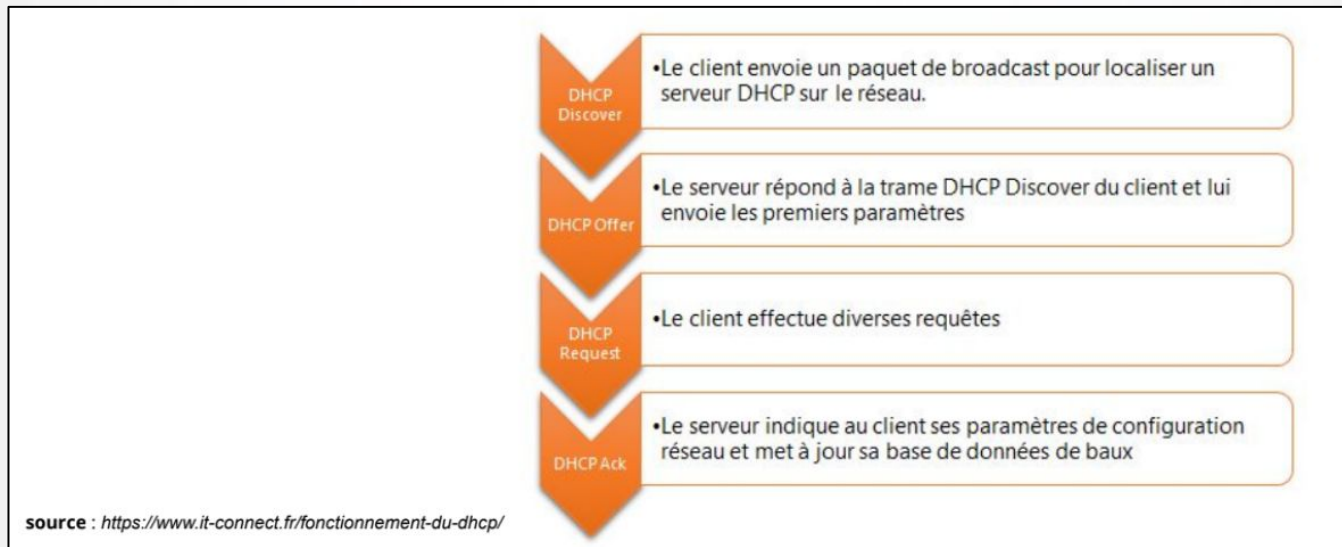
Il est aussi indispensable au fonctionnement d'internet.



Fonctionnement du protocole DHCP

En Anglais, Dynamic Host Configuration Protocol, ce protocole permet à une machine sur le réseau de se connecter de manière dynamique.

- Le client n'a pas besoin de configurer sa machine au préalable.



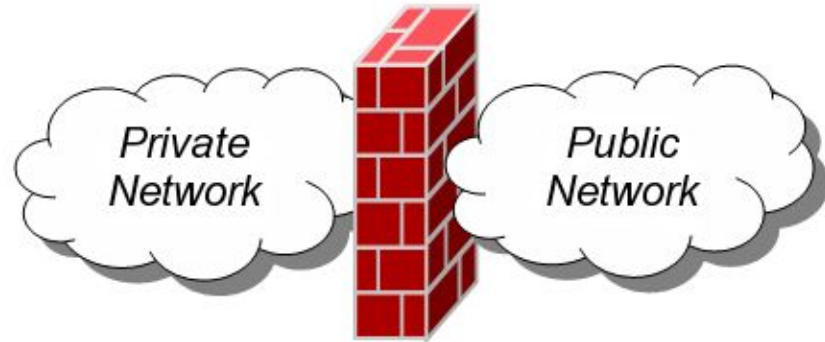


Les différentes attaques sur les réseaux locaux.



Les faiblesses réseaux les plus communes

- Suivi des patches des équipements.
- L'utilisation des mots de passe par défaut sur les équipements.
- Faiblesse des règles de parefeu.
- Attention aux périphériques amovibles.
- BYOD.

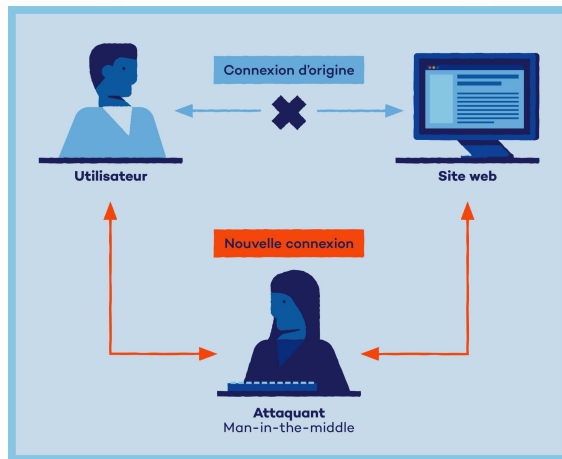


Mind In The Middle (MITM)

L'attaque de l'homme du milieu a pour but d'intercepter toute communication entre deux parties à leur insu.

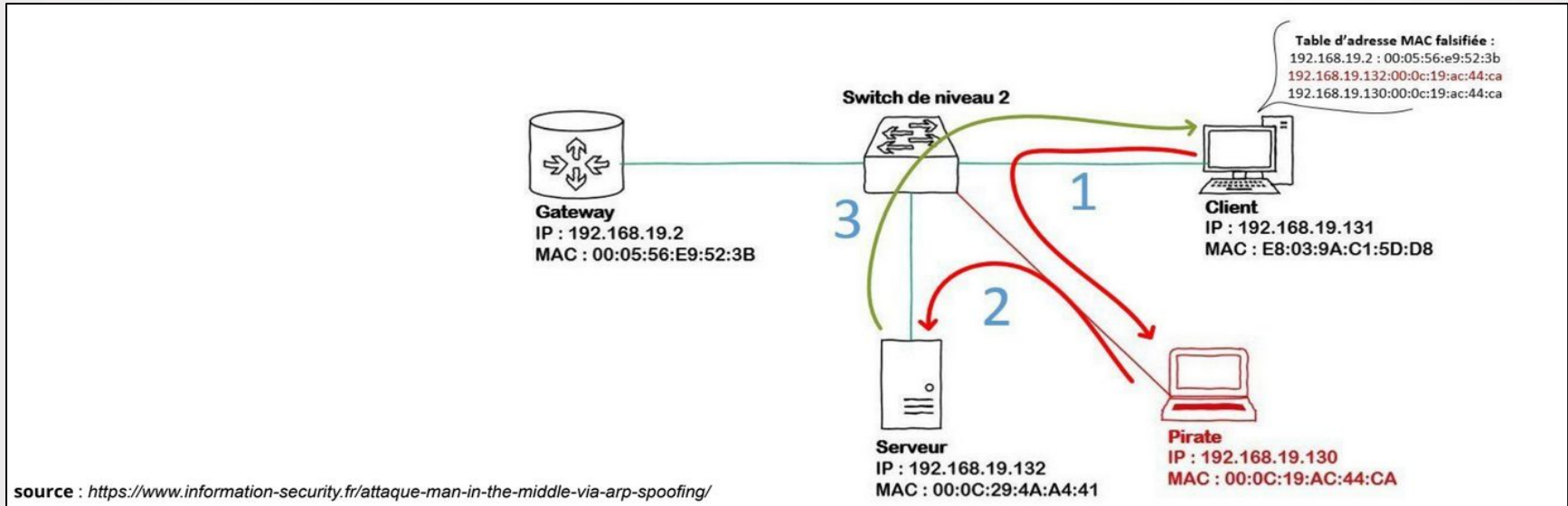
Elle est couramment utilisée pour intercepter la connexion d'un utilisateur sur internet.

- Connexion sur les réseaux sociaux, compte bancaire...



ARP Spoofing

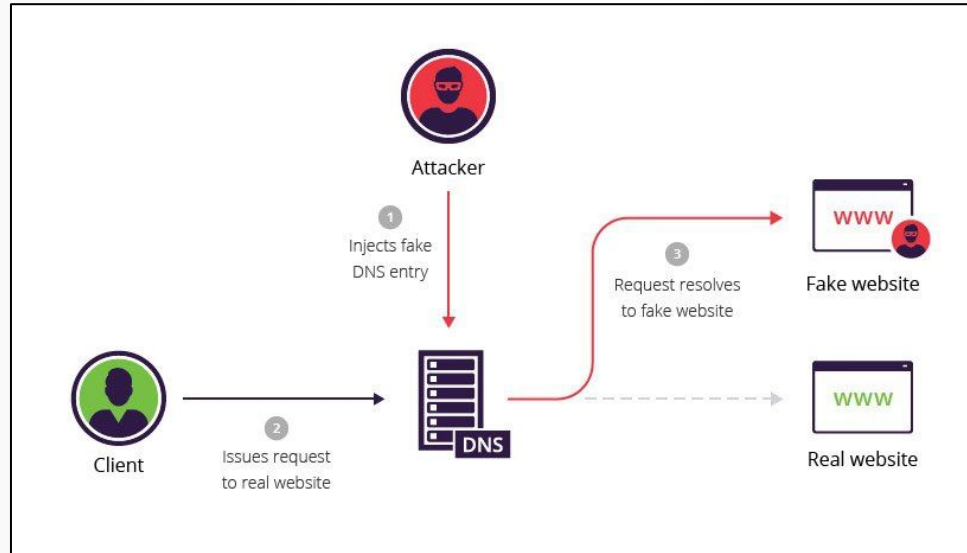
C'est une attaque fréquente qui consiste à forcer les communications entre deux terminaux sur le même réseau local pour **transiter par la machine de l'attaquant** en se faisant passer pour un relais indispensable.



DNS Spoofing

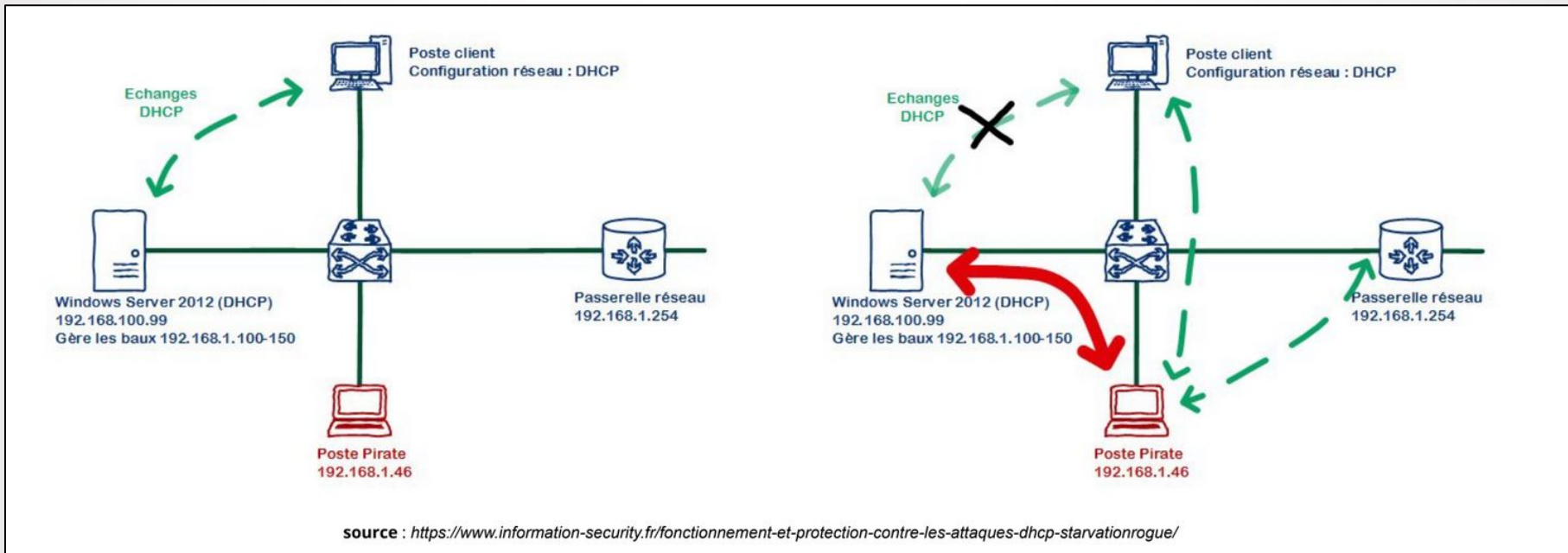
L'objectif de cette attaque est donc de rediriger la victime à son insu vers des sites pirates.

- Peut être fait sur internet comme sur les réseaux locaux.



DHCP starvation

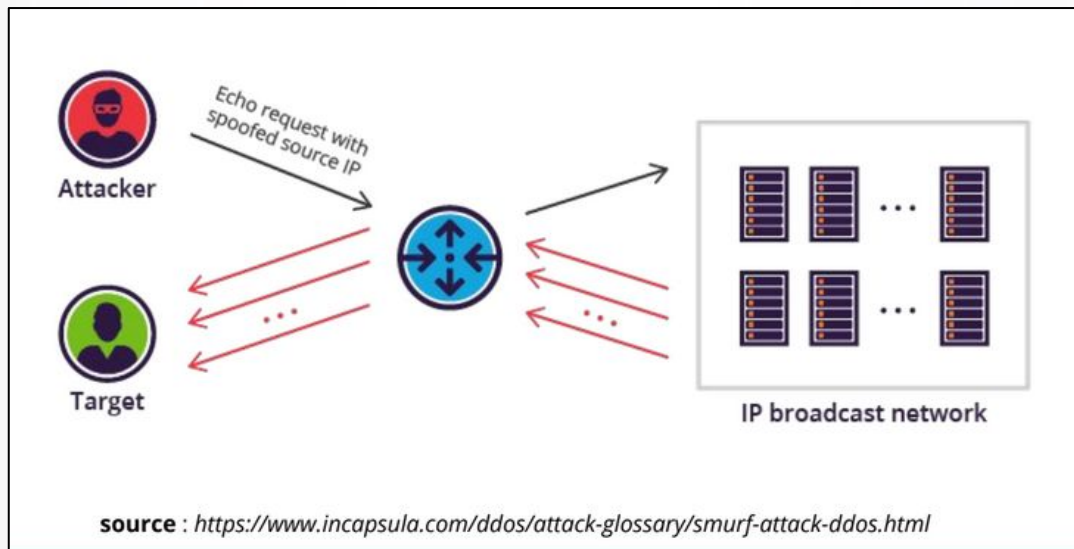
Saturer les baux d'adressage du serveur DHCP afin de le remplacer avec un faux service DHCP.



Les attaques de Déni de Service (DOS)

Les attaques sur la couche réseau/transport (niveau 3 et 4 du modèle OSI)

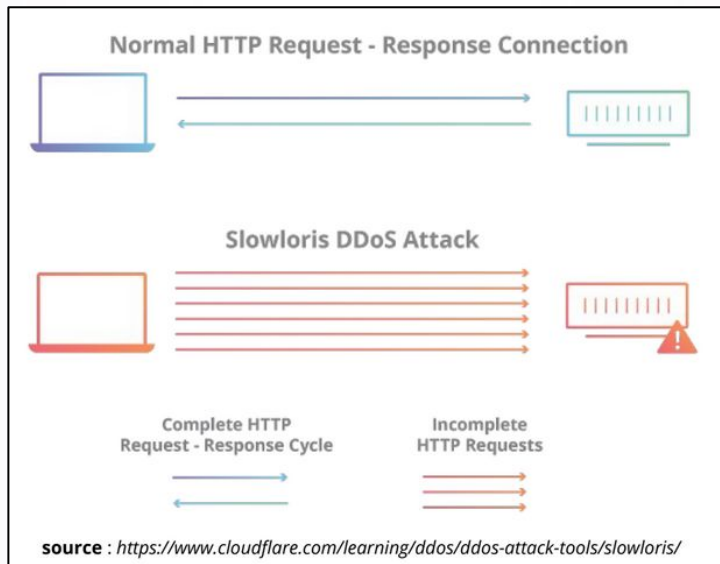
- **SYN flood** : Envoyer un nombre incalculable de paquets TCP SYN sans traitement de la réponse.
- **Smurf DDOS** : Spoofer l'adresse de la victime et envoyer en broadcast des paquets ICMP requests.



Les attaques de Déni de Service (DOS)

Les attaques sur la couche applicative (niveau 7 du modèle OSI)

- **HTTP flood** : Envoyer un nombre incalculable de requêtes web jusqu'à rendre le service inaccessible (les requêtes POST > les requêtes GET).



Comment se prémunir ?

- Mettre en place des enregistrements ARP statiques.
- Configurer proprement le Port security sur les switches.
- Configurer proprement les pare-feux pour rejeter tout trafic suspect.
 - e.g : Rejeter l'ICMP provenant de l'extérieur.
- Détection et blocage via les solutions IDS/IPS.
- Vérification de la réputation de la source et des inputs.

Il existe des solutions commerciales (Cisco/HP...) pour détecter et bloquer ces attaques.

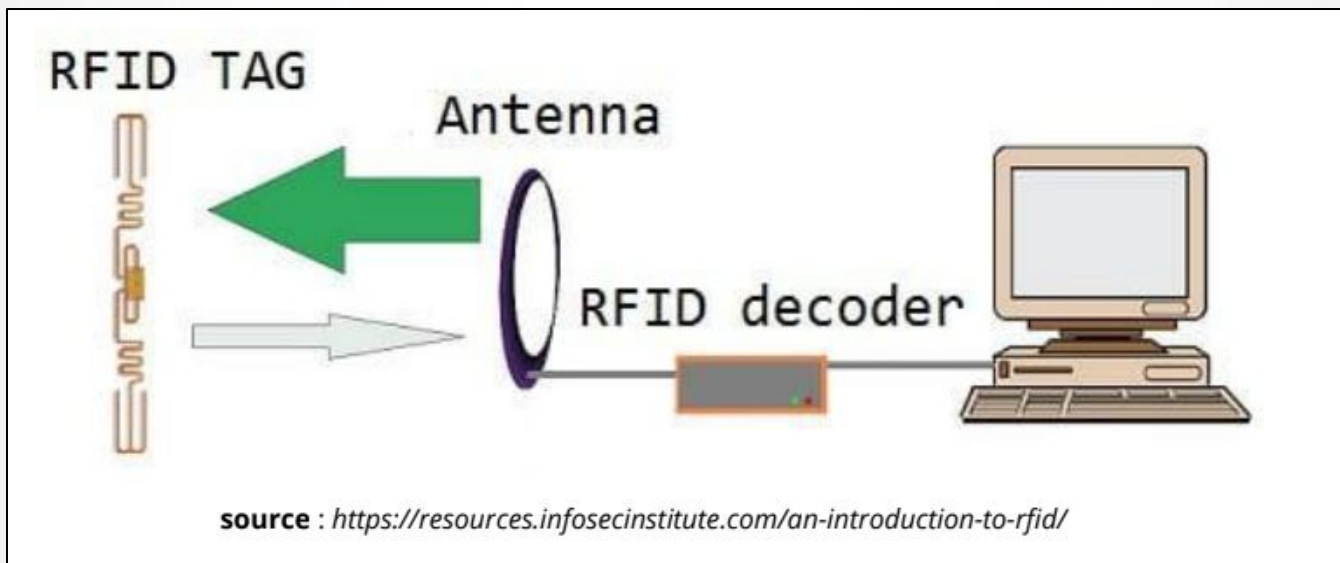


Les différentes attaques sur les réseaux sans fil.



Radio Frequency Identification (RFID)

L'identification par radiofréquence est une technologie permettant aux équipements d'identifier automatiquement les informations enregistrées dans les tags RFID grâce aux ondes radio.



L'utilisation quotidienne de la RFID



Car Keys



Sporting Events



Theme Parks



Libraries



Retail Stores



Tolling Systems

source : <https://starporttech.com/rfid-everyday-life/>

Le fonctionnement de la RFID

- Le lecteur transmet de l'énergie par radio afin d'activer le tag.
- Il interroge ensuite les tags à proximité.
- Il écoute les réponses et élimine les doublons ou les collisions entre les réponses.
- Enfin, il transmet les résultats obtenus aux applications concernées.



Fréquence de fonctionnement

Basse fréquence

- Toute fréquence qui varie de 30 KHz à 300 KHz et une distance de lecture jusqu'à 10 cm.
- En RFID : 125KHz - 134.2 KHz.

Haute fréquence

- Toute fréquence de 3 MHz à 30 MHz et une distance de lecture de 10 cm à 1 m.
- En RFID : 13.56MHz.

Ultra-haute fréquence

- Toute fréquence de 300 MHz à 3 GHz et une distance de lecture jusqu'à 100 m.
- En RFID : 860 MHz - 960 MHz.

Les outils du RFID

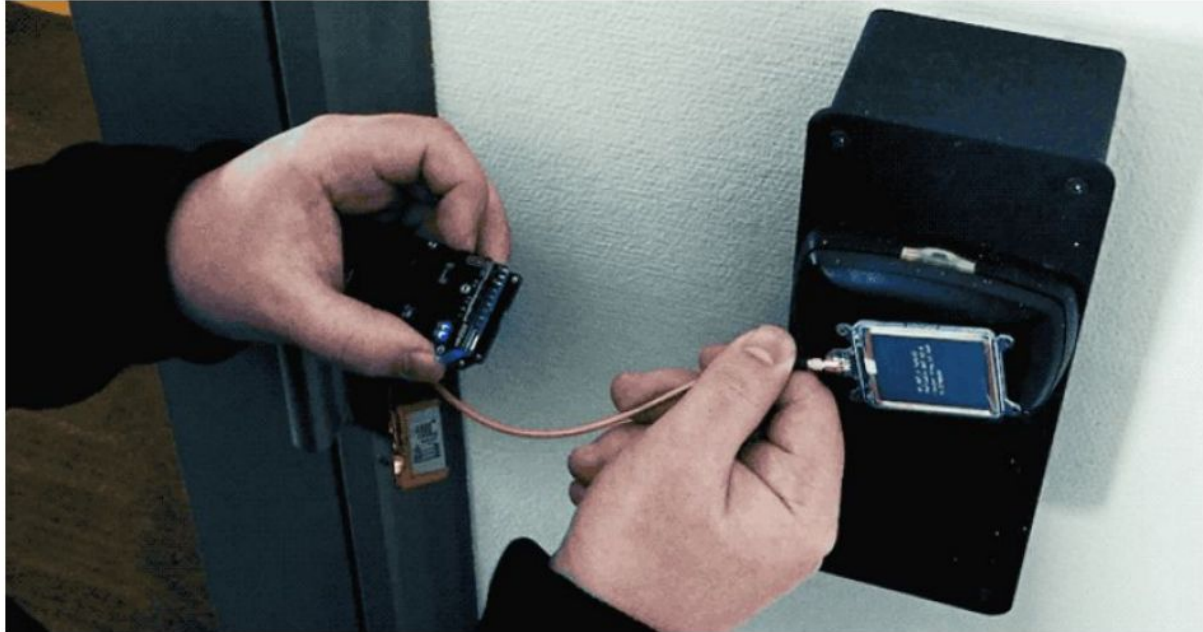
SCM SCL3711



Proxmark3



Démonstration : RFID Hacking



source : <https://professionalhackers.in/hackers-build-a-master-key-that-unlocks-millions-of-hotel-rooms/>

Wifi : Kesako ?

- Désigne un réseau local permettant de relier les équipements sans fil.
- Par abus de langage, le terme est utilisé pour désigner internet.
 - Avez-vous du WiFi chez vous ?
- Il est utilisé presque partout aujourd'hui (même dans les avions).
- Quand ce n'est pas bien configuré, les conséquences peuvent être désastreuses.



Les standards du Wifi (IEEE 802.11)

Protocole	Date de normalisation	Fréquences	Taux de transfert (Typ)	Taux de transfert (Max)	Portée moyenne (intérieur) ^[réf. nécessaire]	Portée (extérieur) ^[réf. nécessaire]
Norme initiale	1997	2,4-2,5 GHz	1 Mbit/s	2 Mbit/s	?	?
802.11a	1999	5,15-5,35 GHz 5,47-5,725 / 5,725-5,875	25 Mbit/s	54 Mbit/s	~25 m	~75 m
802.11b	1999	2,4-2,5 GHz	6,5 Mbit/s	11 Mbit/s	~35 m	~100 m
802.11g	2003	2,4-2,5 GHz	25 Mbit/s	54 Mbit/s	~25 m	~75 m
802.11n	2009	2,4 GHz et/ou 5 GHz	200 Mbit/s	450 Mbit/s	~50 m	~125 m
802.11ac	jan. 2014	5,15-5,35 GHz 5,47-5,875 GHz	433 Mbit/s ¹	1300 Mbit/s	~20 m	~50 m
802.11ax	Est. vers fin 2018	2,4 GHz / 5 GHz		10.53 Gbit/s		

source : https://fr.wikipedia.org/wiki/IEEE_802.11

Les mécanismes de protection Wifi

Standard de chiffrement	Description	Puis-je l'utiliser ?
Wired Equivalent Privacy (WEP)	- Premier standard 802.11 de sécurité. - A été facilement craqué à cause de son vecteur d'initialisation de 24 bits et faible authentification.	Non
Wi-Fi Protected Access (WPA)	- Créé pour remplacer RC4 de WEP par TKIP pour une authentification et un chiffrement plus robuste.	Seulement si WPA2 n'est pas disponible.
Wi-Fi Protected Access 2 (WPA2)	- Remplace RC4 et TKIP par CCMP et AES pour une authentification et un chiffrement plus robuste.	Oui
Wi-Fi Protected Setup (WPS)	- Créé pour rendre la configuration du point d'accès plus simple pour un particulier. - Utilise un PIN sur 7 caractères qui peut être aujourd'hui facilement bruteforcé.	De préférence non. Sinon s'assurer que le routeur n'est pas vulnérable aux attaques WPS.

Comment se prémunir ?

- Utiliser des tags RFID avec des chiffrements réputés et approuvés.
- S'assurer avant tout que les routeurs WiFi utilisés ne sont pas vulnérables.
- Modifier les accès par défaut aux portails d'authentification du routeur.
- Utiliser WPA2 avec passphrase complexe à deviner.
 - Alphanumérique + caractères spéciaux.

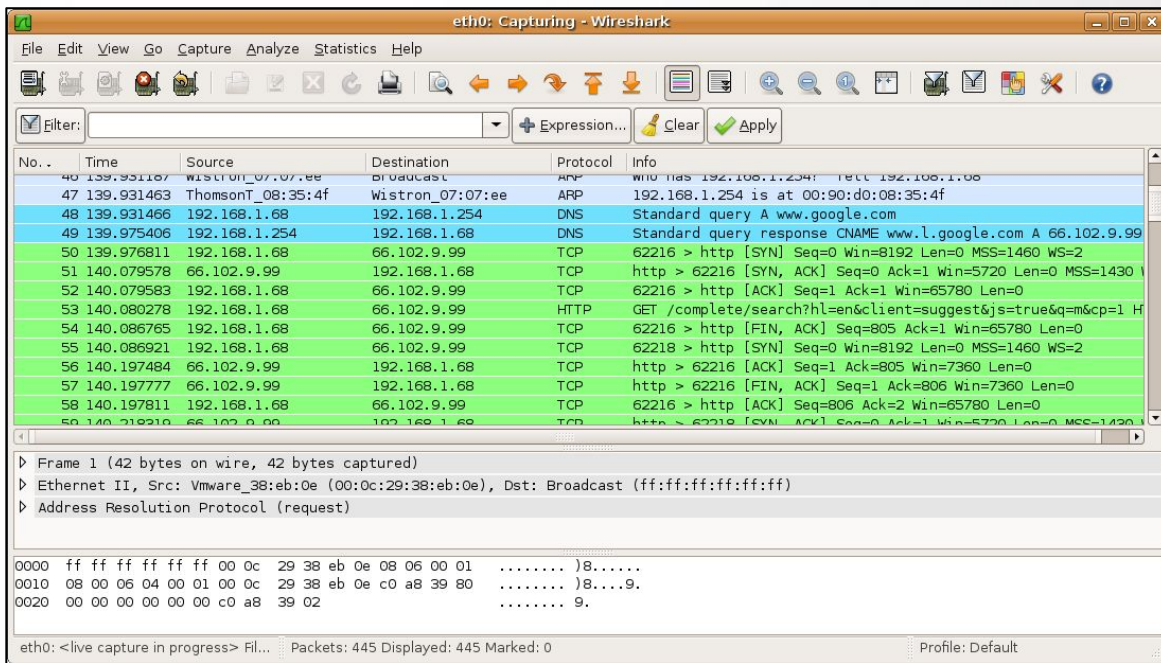




Manipulation des outils.



- Couteau suisse de capture et d'analyse de paquets réseaux.
- Les usages sont multiples :
 - Détection d'incident sur le réseau.
 - Déterminer si une machine est infectée en analysant le trafic d'un éventuel malware.



Ettercap

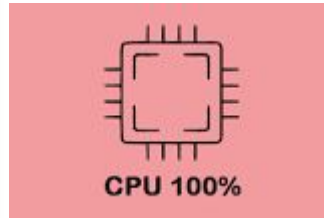
Ettercap est un outil permettant de mettre en place l'attaque de l'homme du milieu (MITM).



Hping3

Hping3 est un outil permettant de réaliser des attaques de type DOS sur les machines du réseau local.

```
linuxhint@LinuxHint:~$ sudo hping3 -S --flood -V -p 80 170.155.9.185
using wlp3s0, addr: 192.168.0.103, MTU: 1500
HPING 170.155.9.185 (wlp3s0 170.155.9.185): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
```



La suite aircrack-ng

- airmon-ng
 - Permet de passer en mode monitor (promiscuous mode).
- airodump-ng
 - Permet de scanner les réseaux wifi apparents et cachés.
- aireplay-ng
 - Permet d'injecter des paquets. Utilisé généralement pour déconnecter des équipements WiFi du réseau.
- aircrack-ng
 - Permet de cracker les clés WiFi.



Wifite

Similaire à la suite aircrack-ng, il permet en mode interactif de lancer des attaques sur les réseaux WiFi.

```
root@kali:~# wifite -showb

WiFiFite v2 (r85)
automated wireless auditor
designed for Linux

[+] target MAC address viewing enabled
[+] scanning for wireless devices...
[+] initializing scan (mon0), updates at 5 sec intervals, CTRL+C when ready.
[0:00:04] scanning wireless networks. 0 targets and 0 clients found
```



1. Démo : Capture and Crack WPA
2. Exercice : Wifi (2)

A yellow L-shaped graphic element consisting of a horizontal line at the top and a vertical line on the right, forming an open square frame.

Fin du Module 3
IPREC